

Rapport de TP : Tests d'API

Exploitation d'un point de terminaison d'API à l'aide de la documentation - PortSwigger Academy

Module :	Tests d'API (API Testing)
Niveau :	Apprenti (Laboratoire Résolu)
Objectif :	Découvrir la documentation d'une API exposée et supprimer le compte de l'utilisateur "carlos".

1. Introduction & Objectifs

Ce laboratoire met en évidence les risques liés à l'exposition publique des documentations d'API (telles que Swagger, OpenAPI ou des interfaces de routage internes). Les développeurs laissent parfois ces documentations accessibles en production, fournissant ainsi aux attaquants une cartographie exhaustive de tous les points de terminaison (*endpoints*), des formats de requêtes et des méthodes HTTP autorisées.

2. Reconnaissance et Découverte de l'API

En interceptant le trafic via le proxy de Burp Suite lors de la mise à jour des informations de compte utilisateur (`wiener:peter`), la requête de base observée est la suivante :

```
PATCH /api/user/wiener HTTP/2
Host: 0a77003a0338f448801d0d7d0048008a.web-security-academy.net
Cookie: session=oS2ukPhGAXw2GqJC7DEXR5YIDAuPBKnK
Content-Type: text/plain;charset=UTF-8

{"email":"wiener@normal-user.net"}
```

Pour cartographier la structure des routes de l'API, des tests successifs d'altération de chemin ont été réalisés dans **Burp Repeater** :

- **Suppression de l'identifiant (`/api/user`)** : Retourne une erreur explicite `{"error": "Malformed URL: expecting an identifier"}`, indiquant que le point de terminaison attend un paramètre d'identification.
- **Suppression du segment utilisateur (`/api`)** : Provoque une redirection HTTP 302 Found vers `/api/`, révélant l'existence d'un répertoire racine pour l'API.

3. Exploitation de la Documentation et Suppression de Carlos

En soumettant une requête GET `/api/`, le serveur renvoie l'interface de documentation interactive de l'API. Cette dernière a été affichée dans le navigateur via l'option *Show response in browser* de Burp Suite.

L'analyse de la documentation interactive a permis d'identifier la route de suppression des utilisateurs, associée à la méthode HTTP **DELETE**.

Action d'exploitation : La méthode a été modifiée dans Burp Repeater pour cibler directement l'utilisateur cible via l'endpoint documenté :

```
DELETE /api/user/carlos HTTP/2
Host: 0a77003a0338f448801d0d7d0048008a.web-security-academy.net
Cookie: session=oS2ukPhGAXw2GqJC7DExR5YIDAuPBKnK
```

La transmission de cette requête a entraîné la suppression effective du compte de Carlos et la résolution immédiate du laboratoire.

4. Recommandations de Remédiation

- **Restreindre l'accès à la documentation :** Les interfaces de documentation d'API (Swagger UI, OpenAPI, ReDoc) ne doivent jamais être exposées publiquement en production. Elles doivent être cantonnées aux environnements de développement ou protégées par une authentification forte d'administration.
- **Contrôle d'accès rigoureux (RBAC / ABAC) :** S'assurer que chaque point de terminaison sensible (notamment les méthodes destructrices comme DELETE ou PUT) vérifie scrupuleusement les privilèges et rôles de l'utilisateur authentifié avant d'exécuter l'action.
- **Validation stricte des méthodes HTTP :** Désactiver les verbes HTTP non utilisés ou superflus sur les endpoints publics pour prévenir le contournement de restrictions.